



SKILL PARA CLAUDE CODE

Auditoria de Segurança

O que a IA não checkou por você

Você pediu um sistema. Ela entregou um sistema que funciona. Funcionar e estar seguro são duas coisas diferentes, e ninguém verificou a segunda.

Numa auditoria de 1.400+ aplicações construídas com IA: 65% tinham falha de segurança, 58% pelo menos uma crítica, e 88% dos apps com Supabase estavam com Row Level Security inteiramente desabilitado.

Segurança aberta é FALHA, não dívida: está errada desde o primeiro dia e custa o mesmo para arrumar hoje ou daqui a um ano.

Palavra-chave desta skill: **BLINDAR**

Como a skill trabalha

A skill lê o projeto inteiro antes de procurar qualquer coisa. Primeiro identifica a stack, o banco, o framework e como a autenticação foi montada — sem isso ela procuraria padrão que não existe ali. Depois varre o código atrás de 12 pontos específicos e entrega um laudo com arquivo, linha e o comando de correção. Ela não corrige nada sozinha: algumas mudanças quebram funcionalidade, e essa decisão é de quem opera.

Crítico

Corrija antes de qualquer pessoa usar o sistema. Cada um destes já é explorável hoje, sem nenhuma habilidade técnica do outro lado.

Row Level Security desligado

Procura tabelas criadas sem ENABLE ROW LEVEL SECURITY nas migrations e cruza com o que o código do browser lê direto do banco. No Supabase, tabela sem RLS aparece marcada como Unrestricted no painel.

Custa: qualquer visitante abre o DevTools, copia a requisição e lê a tabela inteira. Não precisa invadir nada — a API devolve o dado para quem pedir.

Chave de API no frontend

Varre src, app, components e pages atrás de sk-, service_role, STRIPE_SECRET e afins. Em Next.js verifica também as variáveis NEXT_PUBLIC_, que vão para o bundle mesmo quando o nome sugere segredo.

Custa: a chave fica no JavaScript que todo visitante baixa. Qualquer um extrai e usa no seu crédito, e você descobre pela fatura.

Segredo commitado no repositório

Confere se .env está no .gitignore e roda git log no arquivo. Se houver commit, o segredo está no histórico — e apagar o arquivo agora não remove o que já foi versionado.

Custa: quem clonar o repositório tem suas credenciais, hoje e sempre. A correção não é apagar o arquivo: é revogar todas as chaves expostas.

Rota de API sem autenticação

Lista cada rota em app/api, pages/api e routes e verifica se há checagem de sessão antes da lógica. Dá atenção especial às que escrevem, deletam ou cobram.

Custa: chamam a rota direto, sem passar pela sua interface. Toda validação que você fez no formulário deixa de existir.

Alto

Corrija antes de colocar em produção. Exigem um pouco mais de intenção para explorar, mas nenhum deles é difícil.

CORS liberado para qualquer origem

Procura Access-Control-Allow-Origin com asterisco e chamadas de `cors()` sem configuração de domínio.

Custa: qualquer site consegue chamar sua API usando a sessão do seu usuário logado, sem ele perceber.

Sem rate limit em rota cara

Identifica rotas que chamam LLM, enviam e-mail, processam pagamento ou fazem upload, e verifica se existe teto por IP ou por sessão.

Custa: um script simples roda sua cota de API até o teto em uma madrugada. Aconteceu no próprio site da RedPro: 5 rotas disparavam 2 e-mails por chamada, sem limite.

Webhook sem verificação de assinatura

Localiza handlers de webhook (Stripe, Hotmart, Meta) e confere se validam o header de assinatura antes de processar o evento.

Custa: qualquer pessoa forja um evento de pagamento aprovado e libera acesso sem pagar.

Erro devolvendo stack trace

Procura blocos catch que retornam `error.message`, `error.stack` ou o objeto de erro inteiro para o cliente.

Custa: você entrega caminho de arquivo, estrutura de pastas e às vezes nome de variável de ambiente. É mapa da casa para quem quer entrar.

Médio

Corrija em breve. Não são urgência hoje, mas cada um já custou caro para alguém.

Input do usuário indo direto para query

Procura concatenação de string em SQL, operador `$where` em Mongo e template literal montando query.

Custa: injeção — o usuário escreve comando no campo de texto e o banco executa.

Upload sem validar tipo e tamanho

Verifica se os handlers de upload checam MIME type e impõem limite de bytes.

Custa: arquivo executável disfarçado, ou disco cheio por upload de 2GB.

Headers de segurança ausentes

Confere Content-Security-Policy, X-Frame-Options e Strict-Transport-Security. Em Next.js, olha a função `headers()` do `next.config`.

Custa: seu site pode ser embutido em iframe de terceiro para capturar cliques do usuário.

Dependência com CVE conhecido

Roda npm audit ou pip-audit e reporta apenas severidade alta ou crítica que já tenha correção publicada.

Custa: falha pública, com exploração documentada e disponível para qualquer um.

Como usar

1. Baixe o arquivo da skill no link abaixo.
2. Mande o arquivo para o seu Claude Code e diga: *"instala essa skill pra mim"*. Ele resolve o resto.
3. Dentro da pasta do seu projeto, peça: *"auditoria de segurança nesse projeto"*.
4. Leia o laudo. Cada ponto aberto tem arquivo, linha e o que fazer.

<https://redpro.com.br/redreply/skills/auditoria-seguranca.md>